Actividad 1. Estrategia de pruebas — actualización de experiencia 2

Proyecto: Cuidarte+ · **Integrantes:** Antonella Cuvertino y Miriam Hammami · **Fecha:** 20 de octubre de 2026.

Objetivo y alcance

Priorizar riesgos sobre datos de salud, permisos, integridad y continuidad. Incluye login, usuarios/roles, pacientes, exámenes, PDF y auditoría. Excluye pagos, facturación e instrumentos médicos. El PDF original se conserva en esta misma carpeta; esta actualización incorpora el estado real sin alterar retrospectivamente el trabajo anterior.

Riesgos, estrategia y recursos

Crítico: acceso no autorizado y escalamiento; se ejecutan casos negativos por actor y recurso. Alto: credenciales, borrado y auditoría; se contrasta respuesta con base. Rendimiento: se miden tiempos y un lote breve de 200 solicitudes, sin equipararlo a JMeter sostenido. Accesibilidad: se planifica WCAG 2.1 AA con revisión manual y adultos mayores. Enfoque mixto Shift-Left; SAST, integración y pruebas exploratorias complementarias.

Roles propuestos: Antonella QA/DevSecOps y automatización; Miriam diseño, trazabilidad y cumplimiento. Ambas revisan evidencias. Recursos: Windows, Docker, PostgreSQL 15, Node.js, SonarQube, navegador y datos sintéticos. Cronograma relativo: semana 1 entorno y unitarias; semana 2 integración y roles; semana 3 E2E, DAST y carga; semana 4 accesibilidad, retest e informe.

Entrada y salida

Entrada: versión y criterios conocidos, entorno aislado y cuentas por rol. Salida: todos los críticos y altos ejecutados, cero abiertos de esas severidades, cobertura backend >80%, DAST/SAST revisados y accesibilidad/carga completas. No se cumple la salida en esta iteración.

Estado y evidencia

Se ejecutaron doce checkpoints API: seis PASS y seis FAIL. No se implementaron remediaciones. SonarQube se documenta con exportaciones reales si están presentes en 06_Evidencias/sonarqube. Los ocho casos maestros y su correspondencia se encuentran en el informe EP3, apartado 4. El 100% de cobertura ERS no es demostrable sin la ERS completa.

Mejora continua

Priorizar autorización de mutaciones y roles; después hash de contraseña, soft delete, auditoría y demoras. Repetir la suite y ampliar a Jest/Supertest, DAST, E2E, WCAG y carga sostenida. No usar datos personales reales para pruebas.

Actividad 2. Ejecución y evidencias de interfaz — consolidación

Proyecto: Cuidarte+ · **Integrantes:** Antonella Cuvertino y Miriam Hammami · **Fecha:** 20 de octubre de 2026.

Fuente y alcance

Se conserva el PDF original de la actividad 01-10, que declara cinco PASS: acceso/login SPA, dashboard, búsqueda de pacientes, registro/PDF y confirmación de eliminación. Son antecedentes históricos del equipo, no una nueva ejecución validada de toda la UI. No se modifican las capturas originales ni se inventan resultados de un estudio de usabilidad.

Contraste con evidencia técnica actual

El login y el transporte de PDF tienen checkpoints API exitosos. Sin embargo, el backend elimina físicamente el examen: CP-API-007 confirma cero filas después de DELETE. Por ello, CP-UI-05 solo puede interpretarse como confirmación visual y actualización de lista; no demuestra soft delete. La mención de búsqueda “sin latencia perceptible” no reemplaza una medición: el lote API actual tiene p95 de 8698 ms.

Matriz de alcance

Caso histórico	Estado en PDF	Validación actual / limitación
CP-UI-01	PASS declarado	CP-API-001 confirma login técnico; ver acta de capturas para nuevo recorrido UI
CP-UI-02	PASS declarado	Captura actual si consta en acta; sin evaluación completa de widgets
CP-UI-03	PASS declarado	No se midió búsqueda de UI; no extrapolar tiempo de API
CP-UI-04	PASS declarado	CP-API-006 valida transferencia e integridad de bytes
CP-UI-05	PASS declarado	Persistencia FAIL: no cumple borrado lógico

Evidencia y pendientes

El PDF original contiene las evidencias aportadas. Las capturas nuevas y su acta, cuando existan, se guardan en 06_Evidencias/capturas. La evaluación WCAG AA requiere teclado, foco, etiquetas, contraste, zoom y lectores, además de usuarios adultos mayores para usabilidad; no se declara completada por disponer de capturas.

Actividad 3. Rol QA — ejecución y evidencias en Cuidarte+

Adaptación de la guía Atlas y Conecta+. Se aplican riesgos equivalentes al caso semestral Cuidarte+, sin afirmar que se ejecutaron esos otros sistemas. La guía original está en 04_Guias_y_plantillas.

Organización y método

Líder QA propuesto: Antonella; ejecutora propuesta: Antonella; evidencia y relatoría propuestas: Miriam. La ejecución técnica efectiva fue automatizada con asistencia; las integrantes deben revisar resultados. No se corrigieron rutas durante la sesión. Se seleccionan casos equivalentes al Plan Maestro: login válido, entrada obligatoria vacía, acceso ajeno y acción destructiva anónima como riesgo adicional.

Herramienta y registro del flujo

Se usó un runner Node.js fetch con registro JSON, y capturas de navegador cuando constan en el acta. No se dispone de un proyecto nativo exportado por Chrome DevTools Recorder, TestCase Studio o Selenium IDE. Este resultado no se presenta como cumplimiento de esa grabación específica. La guía admite alternativa manual ante problemas; corresponde comunicar a la docente esta diferencia y, si exige la herramienta exacta, grabar el login siguiendo los pasos incluidos en GUIA_DE_ENTREGA.md. Las evidencias API ya están disponibles y no deben reemplazarse por un PASS supuesto.

Cuatro casos obligatorios y bitácora

ID de aula / técnico	Esperado	Obtenido	Estado	Evidencia / incidencia
CP 001 / CP-API-001	200 y JWT verificable	HTTP 200; firma válida=true	PASS	resultados_api.json → CP-API-001
CP 002 / CP-API-003	400 sin inserción	HTTP 400	PASS	resultados_api.json → CP-API-003
CP 003 / CP-API-004	403 sin datos ajenos	HTTP 403	PASS	resultados_api.json → CP-API-004
CP 004 / CP-API-012	401 y cuenta intacta	HTTP 200; filas restantes=0	FAIL	resultados_api.json → CP-API-012 / DEF-006

Incidencia reproducible y cierre

DEF-006: DELETE /usuarios/:id sin Bearer elimina una cuenta sintética y responde HTTP 200. Esperado: 401 y fila intacta. Obtenido: 200 y cero filas; criticidad crítica por acción destructiva anónima. Entorno: API 4445, PostgreSQL aislado. Pasos y datos exactos: ejecutar_api.cjs, CP-API-012. Recomendación: autenticar y autorizar antes de ejecutar DELETE; validar persistencia y regresión. Los cuatro casos equivalentes cuentan con resultado y evidencia; hay tres PASS y un FAIL. No se declara una duración real de 80 minutos ni grabación nativa inexistente.

Actividad 4. Preparación y presentación del informe de certificación

ISY1102 · EA2 · IL2.4 · Cuidarte+ · Antonella Cuvertino y Miriam Hammami. Documento de preparación individual para estudiar y defender los resultados del trabajo compartido. Cada estudiante debe sostener el dictamen con sus propias palabras.

1. Resumen ejecutivo

Dictamen: NO CERTIFICADO. Alcance: API de autenticación, usuarios/roles, exámenes, PDF y auditoría; carga breve y análisis estático según evidencias. Dos defectos críticos permiten escalamiento de médico a administrador y eliminación anónima. No se recomienda producción con datos de salud.

2. Métricas de ejecución

Indicador	Valor real
Casos maestros diseñados	8; no todos ejecutados integralmente
Checkpoints API diseñados	12
Checkpoints API ejecutados	12 (100% de esa suite)
PASS	6 (50% de ejecutados)
FAIL	6
BLOCKED en suite API	0
Casos maestros SQLi / WCAG	Pendientes; no incluidos como PASS
Carga breve separada	1 ejecutada, FAIL; p95 8698 ms

Los números 50, 48 y 42 de la guía son ejemplos y no datos del proyecto. El lote de carga, el análisis estático y la UI histórica no se suman al denominador de doce checkpoints.

3. Gestión de defectos

ID	Nivel	Hallazgo	Estado
DEF-001	GRAVE / Alta	Auditoría sin origen IP	Abierto; sin retest de cierre
DEF-002	GRAVE / Alta	Contraseñas en texto claro	Abierto; sin retest de cierre
DEF-003	GRAVE / Alta	Eliminación física de exámenes	Abierto; sin retest de cierre
DEF-004	GRAVE / Alta	Latencia fuera de criterio	Abierto; sin retest de cierre
DEF-005	CRÍTICO	Escalamiento de médico a administrador	Abierto; sin retest de cierre
DEF-006	CRÍTICO	Eliminación de usuario sin autenticar	Abierto; sin retest de cierre

4. Matriz de trazabilidad

Requisito	Caso	Resultado
RF-1.1	CP-API-001	PASS
RF-1.1	CP-API-002	PASS
RF-3.1	CP-API-003	PASS
NFR-SEG-4	CP-API-004	PASS
NFR-SEG-9	CP-API-005	PASS

Requisito	Caso	Resultado
RF-3.1; RF-4.3/4.4	CP-API-006	PASS
RF-3.3	CP-API-007	FAIL
NFR-SEG-2	CP-API-008	FAIL
RF-5.1	CP-API-009	FAIL
NFR-SEG-4	CP-API-010	FAIL
NFR-PERF-1	CP-API-011	FAIL
NFR-SEG-4	CP-API-012	FAIL

5. Evaluación de riesgos

Riesgos mitigados por corrección en esta sesión: ninguno, porque la actividad evalúa sin modificar código. Controles observados: rechazo de credenciales/JWT inválidos e IDOR en las rutas probadas. Riesgos residuales: seis defectos abiertos, autorización en otras rutas, auditoría sin protección integral demostrada, ausencia de cobertura instrumentada, DAST y validación WCAG. Riesgos aceptados formalmente: ninguno; no existe aprobación documentada para aceptar críticos.

6. Conclusión y recomendación final

El criterio exige cero críticos/graves abiertos y ejecución completa del alcance de alto riesgo. Se detectaron dos críticos y cuatro graves; el criterio no se cumple. Primero corregir autorización de usuarios y roles, luego contraseñas, conservación, auditoría y latencia. Después retest y regresión con evidencia por versión; ampliar a ERS, DAST, WCAG y carga sostenida antes de reevaluar certificación. La recomendación protege confidencialidad y continuidad de datos de salud y no atribuye multas automáticas por cada defecto.